

פרק 1 – מבוא לאיומי רשת חדשים

10 שעות עיוני · שבועות 1-3

מטרות: אבולוציית אבטחת המידע · כלים לאבטחה · מערכות והתקפת מערכות
בבגרות: phishing, סוגי תוקפים, brute force, DoS, buffer overflow

לפני שמתחילים – מושגי יסוד ברשת (למי שאין רקע)

כדי להבין איומים ואבטחה, צריך קודם להבין מה זו בכלל רשת. הנה כל מה שצריך, בשפה פשוטה: **מחשב מארח** (Host) – כל מכשיר ברשת: מחשב, טלפון, שרת, מדפסת. **כתובת IP** – ה"כתובת" של המכשיר ברשת, כמו כתובת בית (למשל 192.168.1.10). לפיה יודעים לאן לשלוח מידע. **כתובת MAC** – מספר סידורי ייחודי "צרוב" בכרטיס הרשת של כל מכשיר (למשל 0C:0E:15:22:05:97). כמו מספר שלדה של רכב. **חבילה** (Packet) – המידע ברשת לא נשלח כמקשה אחת אלא נחתך ל"מעטפות" קטנות. כל חבילה נושאת כתובת מקור וכתובת יעד, בדיוק כמו מעטפה בדואר. **שרת** (Server) ו**לקוח** (Client) – הלקוח מבקש שירות (הדפדפן שלכם), השרת נותן אותו (אתר האינטרנט). הלקוח שואל, השרת עונה. **נתב** (Router) – מכשיר שמעביר חבילות בין רשתות שונות (למשל בין הרשת בבית לאינטרנט). "צומת דרכים". **מתג** (Switch) – מכשיר שמחבר מכשירים בתוך אותה רשת מקומית (כל המחשבים במשרד). **פרוטוקול** – "שפה"/כללים מוסכמים שמכשירים מדברים בהם (HTTP) לאתרים, DNS לתרגום שמות). כמו כללי נימוס בשיחת טלפון. **פורט** (Port) – "דלת" ממוספרת במכשיר לכל שירות (80 לאתר, 443 לאתר מאובטח, 22 ל-Ssh). כל כתובת IP יש 65,535 דלתות כאלה. כל אלה מוסברים בהרחבה ביחידת "תזכורת רשתות תקשורת". **הרעיון המרכזי של הקורס:** בכל נקודה כזו – מכשיר, כתובת, חבילה, פורט – תוקף יכול לנסות לתקוף, ואנחנו נלמד להגן.

1.1 מהי אבטחת מידע ולמה הרשת היא שדה הקרב

אבטחת מידע (Information Security) היא ההגנה על מידע ועל המערכות שמעבדות אותו מפני גישה, שימוש, חשיפה, שיבוש, שינוי או השמדה בלתי מורשים. **אבטחת רשת** (Network Security) היא תת-תחום: ההגנה על התשתית שמעבירה את המידע – נתבים, מתגים, חומות אש, קווי תקשורת – ועל התעבורה שעוברת בהם. ההבחנה המרכזית שכדאי להציג לתלמידים כבר ביום הראשון: **נכס** (asset) · **איום** (threat) · **פגיעות** (vulnerability) · **סיכון** (risk) · **בקרה** (control).

נכס (Asset)	מה שמגנים עליו: מידע לקוחות, שרתים, מוניטין, זמינות שירות.
פגיעות (Vulnerability)	חולשה במערכת: באג בתוכנה, סיסמה חלשה, פורט פתוח, עובד שלא הוכשר.
איום (Threat)	גורם שעלול לנצל פגיעות: האקר, נזקה, עובד ממורמר, גם שריפה או הצפה.
ניצול (Exploit)	הדרך/הקוד הקונקרטי שבו האיום מנצל את הפגיעות.
סיכון (Risk)	הסתברות שהאיום יממש את הפגיעות × הנזק שייגרם. סיכון = איום × פגיעות × ערך הנכס.
בקרה (Control / Countermeasure)	אמצעי שמקטין סיכון: חומת אש, הצפנה, נוהל, מנעול.

שלושת עקרונות היסוד – CIA Triad

עיקרון	משמעות	דוגמה לפגיעה	אמצעי הגנה אופייני
סודיות (Confidentiality)	רק מי שמורשה רואה את המידע	האזנה (sniffing), דליפת DB, Telnet-ל	הצפנה (AES, SSH, VPN), בקרת גישה, ACL
שלמות (Integrity)	המידע לא שונה בדרך או במנוחה ללא הרשאה	שינוי סכום בהעברה, בנקאית, MITM	גיבוב (SHA), HMAC, חתימה דיגיטלית
זמינות (Availability)	המידע והשירות נגישים כשצריך	DDoS, כופרה, כשל חומרה	יתירות, גיבויים, IPS, סינון תעבורה

שני מושגים נלווים שנשאלים לעיתים: **אימות** (Authentication) – מי אתה) ו**אי-הכחשה** (Non-repudiation) – השולח לא יכול להכחיש ששלח; מושג באמצעות חתימה דיגיטלית, פרק 7).

שאלת תלמיד: "למה צריך שלושה? הרי אם מצפינים הכול – הכול בסדר"

הצפנה נותנת סודיות בלבד. קובץ מוצפן עדיין יכול להימחק (פגיעה בזמינות) או להיות מוחלף בקובץ מוצפן אחר (שלמות). כופרה (Ransomware) היא הדוגמה המושלמת: היא מצפינה את הקבצים שלכם – ובכך פוגעת בזמינות. הצפנה בידיים הלא נכונות היא נשק.

סיפור מהחיים: בית החולים שביטל ניתוחים (WannaCry), מאי 2017

בבוקר יום שישי אחד, מחשבים ב-80 בתי חולים של ה-NHS באנגליה הציגו מסך אדום: "הקבצים שלך הוצפנו. שלם \$300 בביטקוין". המערכות לתורים, לתוצאות בדיקות ולמכשירי הדמיה הפסיקו לעבוד. 19,000 תורים וניתוחים בוטלו, אמבולנסים הופנו לבתי חולים אחרים. הנוזקה לא "גנבה" כלום – היא פשוט מנעה גישה. זו פגיעה **בזמינות**. ואיך היא התפשטה? דרך פגיעות ב-SMB של Windows שמיקרוסופט כבר תיקנה חודשיים קודם – אבל בתי החולים לא התקינו את העדכון. המסקנה לכיתה: עדכון תוכנה הוא אמצעי אבטחה, ולא מטרד.

1.2 אבולוציית אבטחת הרשת – ציר זמן

שנה	אירוע	מה השתנה בעקבותיו
1971	Creeper – "וירוס" הניסוי הראשון ב-ARPANET, ואחריו Reaper שנכתב כדי למחוק אותו	ההוכחה שקוד יכול להתפשט ברשת
1983	פרד כהן טובע את המונח "וירוס" מחשב	תחילת המחקר האקדמי
1988	תולעת מוריס – ~10% ממחשבי האינטרנט מושבתים תוך יום. ניצלה חולשות ב-sendmail וב-finger וניחוש סיסמאות	הקמת ה-CERT הראשון (Carnegie Mellon); החוק הפדרלי הראשון להרשעה בפריצה
1990s	חומות אש מסחריות (Check Point FireWall-1, 1994), IDS ראשונים (Snort, 1998), SSL (1995)	מודל "הגנה היקפית" – פנים מהימן, חוץ עוין
2004-2000	ILoveYou (2000), Code Red (2001), SQL Slammer (2003) – 75,000 שרתים ב-10 דקות, Blaster, Sasser	תולעים שמנצלות חולשות ידועות ⇒ תרבות ה-patching, Windows Update אוטומטי, IPS
2010-2007	מתקפת DDoS על אסטוניה (2007); Stuxnet (2010) – נוזקה שפגעה בצנטריפוגות גרעיניות	לוחמת סייבר בין מדינות; APT (איום מתמשך מתקדם)
2017-2013	פריצת 40 Target מיליון כרטיסי אשראי דרך ספק מיזוג אוויר, Mirai botnet (2016) – מצלמות (2017 WannaCry, IoT) – כופרה שניצלה 200,000 SMB, מחשבים ב-150 מדינות	אבטחת שרשרת אספקה, IoT, כופרה כמודל עסקי

שנה	אירוע	מה השתנה בעקבותיו
2020-היום	SolarWinds (2020) - פריצה דרך עדכון תוכנה, Log4Shell (2021), כופרה כשירות (RaaS), דיפ-פייק והנדסה חברתית מבוססת AI	מודל Zero Trust - "לעולם אל תסמוך, תמיד תאמת"; אין יותר "פנים מהימן"

טיפ להוראה

אל תקריאו את הטבלה. בחרו 3 סיפורים ותספרו אותם: תולעת מוריס (סטודנט שרצה "למדוד את האינטרנט" והסתבר), Target (איך מזגן הפיל רשת ענק) ו-WannaCry (בית חולים באנגליה שביטל ניתוחים). תלמידים זוכרים סיפורים, לא שנים.

סיפור מהחיים: הסטודנט שהפיל את האינטרנט בטעות (תולעת מוריס, 1988)

רוברט מוריס, סטודנט בן 23 בקורנל, כתב תוכנית שנועדה "למדוד כמה גדול האינטרנט" - היא הייתה אמורה להעתיק את עצמה למחשב פעם אחת. בגלל באג, היא שאלה כל מחשב "אתה כבר נגוע?" ואם הוא ענה "כן" - בכל זאת הדביקה אותו מחדש ב-1 מ-7 מהמקרים (מוריס חשש שמנהלים יזייפו "כן"). התוצאה: כל מחשב הריץ מאות עותקים עד שקרסו 6,000 מחשבים - כעשירית מהאינטרנט דאז - הושבתו. מוריס היה האדם הראשון שהורשע לפי חוק הונאת המחשבים האמריקאי. היום הוא פרופסור ב-MIT. השאלה לכיתה: האם זה היה ירוס או תולעת? (תולעת - התפשטה לבד דרך הרשת ללא מגע אדם.)

1.3 מי תוקף? סוגי תוקפים (Threat Actors)

נושא שנשאל ישירות בבגרות (שאלה ג6). חשוב להבחין לפי מניע ויכולת:

סוג	מי הוא	מניע	רמת יכולת
Script Kiddie	חובבן שמריץ כלים שאחרים כתבו, בלי להבין את התהליך	סקרנות, יוקרה, שעמום	נמוכה - אבל הכלים חזקים
Hacktivist	תוקף ממניעים אידיאולוגיים/פוליטיים (Anonymous)	מחאה, השחתת אתרים, הדלפות	בינונית
פשע מאורגן (Organized crime / Cybercriminal)	קבוצה מאורגנת שמטרתה רווח כספי	כסף: כופרה, גניבת כרטיסי אשראי, הונאות	גבוהה, משאבים רבים
Insider (איום פנימי)	עובד/קבלן עם גישה מורשית שמשתמש בה לרעה (או ברשלנות)	נקמה, כסף, טעות	מסוכן במיוחד - כבר בפנים
מדינה (State-sponsored / APT)	יחידות סייבר ממשלתיות	ריגול, חבלה בתשתיות	הגבוהה ביותר, סבלנות של שנים
White hat / Gray hat / Black hat	חלוקה לפי אתיקה: white - בודק חדירה באישור; black - פושע; gray - פורץ ללא אישור אבל מדווח		

סיפור מהחיים: איך מזגן הפיל רשת קמעונאית (Target, 2013)

רשת החנויות Target איבדה פרטי 40 מיליון כרטיסי אשראי. התוקפים לא פרצו ל-Target ישירות - הם שלחו phishing לחברה קטנה בפנסילבניה שמתחזקת את מערכות המיזוג של Target, גנבו את פרטי ההתחברות שלה לפורטל הספקים, ומשם - כי הרשת לא הייתה מפולחת - הגיעו לקופות. שלושה לקחים שממפים ישירות לקורס: (1) הנדסה חברתית היא נקודת הכניסה הנפוצה ביותר; " (2) יחסי אמון" עם צד

שלישי הם פגיעות (3); (Trust exploitation); פילוח רשת (VLAN, ACL) - פרקים 4 ו-6 (היה עוצר את התנועה הרוחבית).

1.4 נזקות: וירוסים, תולעים, סוסים טרויאנים ועוד

נוזקה (Malware = malicious software) הוא שם כולל. ההבחנה בין שלושת הסוגים הקלאסיים היא לפי איך הם מתפשטים:

סוס טרויאני (Trojan)	תולעת (Worm)	וירוס (Virus)	הגדרה
תוכנה שנראית לגיטימית אך מכילה קוד זדוני	תוכנית עצמאית שמשכפלת את עצמה דרך הרשת	קוד זדוני שמצמיד את עצמו לקובץ/תוכנה לגיטימית	
הוא עצמו "המארח" המזויף	לא - עומד בפני עצמו	כן - נדבק לקובץ	צריך מארח?
המשתמש - מתקין אותו מרצון (חושב שזה משחק/crack)	הוא עצמו - מנצל פגיעות ברשת אוטומטית	המשתמש (מריץ את הקובץ הנגוע, מעתיק בדיסק-און-קי)	מי מפיץ?
לא	כן, ובמהירות	כן	משכפל את עצמו?
Zeus (בנקאות), RAT (שליטה מרחוק)	Morris, Slammer, WannaCry	Melissa (1999 Word) מאקרו ב-	דוגמה

סוגי נזקות נוספים שכדאי להכיר

- Ransomware (כופרה) - מצפינה קבצים ודורשת תשלום. כיום הסוג המזיק ביותר לארגונים.
- Spyware / Keylogger - מרגל, מתעד הקשות.
- Adware - פרסומות; לרוב מטריד יותר ממסוכן.
- Rootkit - מסתתר עמוק במערכת ההפעלה (kernel) ומסווה נזקות אחרות; קשה מאוד לגילוי.
- Botnet / Bot / Zombie - מחשבים נגועים הנשלטים מרחוק על ידי C&C (Command & Control) ומשמשים ל-DDoS, spam, כריית מטבעות.
- Logic bomb - קוד ש"מתפוצץ" בתנאי מסויים (תאריך, פיטורי העובד).
- Backdoor - דלת אחורית שעוקפת אימות. יכולה להיות מותקנת על ידי טרויאני או להישאר מכוונה בקוד.

שאלת תלמיד: "אנטי-וירוס מספיק?"

אנטי-וירוס קלאסי מזהה לפי **חתימות** (signature) - תבניות של נזקות ידועות. נזקה חדשה (zero-day) או נזקה שעברה שינוי קל (polymorphic) לא תזוהה. לכן כיום משלבים: ניתוח התנהגות (EDR), (heuristics), עדכוני מערכת, הגנת רשת (IPS), והכי חשוב - משתמש שלא לוחץ על כל דבר. "הגנה לעומק" (Defense in Depth) - כמה שכבות עצמאיות, כך שכשל באחת לא מפיל הכול.

1.5 חקר ההתקפות - שלושת השלבים

מרבית התקפות הרשת מתחלקות לשלוש קטגוריות שסיסקו מגדירה, ואפשר גם לתאר אותן כשלבים בזמן:

1. **סיור / איסוף מידע** (Reconnaissance) → 2. **השגת גישה** (Access) → 3. **מניעת שירות** (DoS) או **ניצול**

מודל מפורט יותר, Cyber Kill Chain של לוקהיד-מרטין: De- → Weaponization → Reconnaissance → Installation → Exploitation → livery Actions on Objectives. הרעיון: אם שוברים חוליה אחת בשרשרת - התקיפה נכשלת.

1.5.1 איסוף מידע (Reconnaissance)

התוקף לומד את המטרה לפני שנוגע בה. הבחינו בין:

- **סיור אקטיבי** - שליחת חבילות: Ping sweep - פינג לכל הכתובות בטווח כדי לגלות אילו מארחים חיים. Port scan - בדיקה אילו פורטים פתוחים בכל מארח (Nmap). פורט 22 פתוח ⇒ SSH; 445 ⇒ RDP; 3389 ⇒ SMB Fingerprinting - זיהוי מערכת ההפעלה והגרסה. (Nmap-O, banner grabbing) Packet sniffing - האזנה לתעבורה (Wireshark) - יעיל במיוחד ברשת אלחוטית פתוחה או כשמשתמשים בפרוטוקולים לא מוצפנים. (Telnet, HTTP, FTP)

1.5.2 התקפות גישה (Access attacks)

התקפה	איך זה עובד	הגנה
Brute – Password attack force / Dictionary	ניסוי שיטתי של כל הצירופים (brute force) או של רשימת מילים נפוצות. (dictionary). כלים: John the Ripper, Hydra. בבגרות: "ניסיון לגלות סיסמה ע"י מילון" = Brute force attack.	סיסמאות ארוכות ומורכבות, נעילה אחרי X ניסיונות, MFA, האטת ניסיונות
Trust exploitation	ניצול יחסי אמון: אם שרת A סומך על B, פורצים ל-B (החלש) ומשם ל-A	מזעור יחסי אמון, פילוח רשת
Port redirection	מארח שנפרץ (ב-DMZ) משמש כ"קופץ" להעברת תעבורה למארח פנימי שחומת האש לא מאפשרת אליו גישה ישירה	HIPS, מודל אמון נכון בין DMZ לפנים
Man-in-the-Middle (MITM)	התוקף מכניס את עצמו בין שני צדדים ומקשיב/משנה (ARP spoofing ברשת מקומית - פרק 6; Evil Twin ב-Wi-Fi)	הצפנה עם אימות (TLS, SSH fingerprint), בדיקת DAI
Buffer overflow	שליחת קלט ארוך מהחוצץ שהוקצה לו, כך שהוא "גולש" ודורס זיכרון - כולל כתובת החזרה - ומריץ קוד של התוקף	עדכוני תוכנה, DEP/ASLR, בדיקת קלט
Social engineering	מניפולציה של בני אדם - ראו 1.6	הדרכה, נהלים

DoS (Denial of Service): הפיכת שירות ללא זמין למשתמשים הלגיטימיים - על ידי הצפה בתעבורה או ניצול באג שמקריס את השירות. DDoS (Distributed): אותו דבר, אבל ממקורות רבים במקביל (botnet) - קשה לחסום כי אין כתובת מקור אחת.

התקפה	מנגנון
Ping of Death	שליחת חבילת ICMP גדולה מ-65,535 בתים (בעזרת פרגמנטציה); מערכות ישנות קרסו בהרכבה מחדש. היסטורי - היום מתוקן, אך נשאל בבחינות.
SYN flood	שליחת המוני SYN בלי לסיים את לחיצת היד המשולשת; טבלת החיבורים "החצי-פתוחים" של השרת מתמלאת ולקוחות אמיתיים נדחים. הגנה: SYN cookies, TCP intercept, SYN flood protection.

התקפה	מנגנון
Smurf	שליחת פינג לכתובת broadcast עם כתובת מקור מזויפת של הקורבן; כל המחשבים ברשת עונים לקורבן (הגברה). הגנה: no ip directed-broadcast (ברירת מחדל היום).
(DNS, NTP) Amplification / Reflection	שאיילתה קטנה עם IP מקור מזויף $\Rightarrow$ תשובה גדולה נשלחת לקורבן. יחס הגברה של פי 50 ויותר.
(HTTP flood, Application-layer DoS Slowloris)	בקשות "לגיטימיות" רבות או חיבורים שנשארים פתוחים לאט – מתישים את השרת.

הגנות מפני DoS: סינון בכניסה לרשת (anti-spoofing ACL) – פרק IPS, rate limiting, (4, שירותי ניקוי תעבורה בענן (Cloudflare, Akamai), יתירות ורוחב פס עודף, ip verify unicast reverse-path (uRPF).

1.6 הנדסה חברתית ו-Phishing

ההתקפה שלא צריכה אף פגיעות טכנית – היא מנצלת את האדם. סוגים:

- Phishing – דוא"ל/SMS שמתחזה לגוף לגיטימי (בנק, UPS, משרד) ומבקש ללחוץ על קישור, "לאשר פרטים" או לפתוח קובץ. Spear phishing – ממוקד לאדם ספציפי עם פרטים אמיתיים עליו. Whaling – ממוקד למנכ"ל. Smishing / Vishing – ב-SMS / בטלפון.
- Pretexting – סיפור כיסוי ("אני מהתמיכה, צריך את הסיסמה שלך כדי לתקן").
- Baiting – דיסק-און-קי "אבוד" בחניה עם תווית "משכורות".
- Tailgating / Piggybacking – כניסה פיזית בעקבות עובד מורשה.
- Quid pro quo – "תן לי גישה ואתן לך מתנה".

בבגרות (שאלה 4א): איך מזהים הודעת phishing? סימנים לחפש

1. כתובת השולח לא תואמת לארגון (UPS) ששולח מ-@hotmail.com. 2. תחושת דחיפות/איום ("Last Call!", "החשבון ייחסם"). 3. בקשה לאשר/להזין פרטים דרך כפתור. 4. שגיאות ניסוח, לוגו מטושטש, פנייה כללית ("Dear customer"). 5. קישור שהטקסט שלו שונה מהיעד האמיתי (מרחפים עם העכבר).
- התשובה:** Social Engineering.

סיפור מהחיים: הסמנכ"ל ששילם 40 מיליון (הונאת "מנכ"ל", 2016)

עובד כספים בחברת Crelan הבלגית קיבל מייל "מהמנכ"ל": "אנחנו ברכישה סודית, העבר דחוף 70 מיליון אירו לחשבון הזה, אל תדבר עם אף אחד". הכתובת הייתה דומה לכתובת המנכ"ל בהבדל אות אחת. הכסף הועבר. זו הנדסה חברתית מסוג BEC (Business Email Compromise) – בלי נזקה, בלי פריצה, רק פסיכולוגיה: סמכות + דחיפות + סודיות. שאלו את התלמידים: איזה נוהל (בקרה מנהלית) היה מונע את זה? (אישור כפול לכל העברה מעל סכום, ואימות טלפוני בערוץ נפרד).

1.7 שיכון מתקפות ברוט-פורס – ומה אפשר לעשות כבר בנתב

"ברוטלי" בתכנית = Brute force. עקרונות ההגנה:

1. **סיסמאות חזקות** – אורך חשוב יותר ממורכבות. 8 תווים מאותיות קטנות $= 26^8 \approx 200$ מיליארד (נפרץ בדקות ב-12 GPU); תווים מכל הסוגים $= 95^{12} \approx 5 \times 10^{23}$. משפט-סיסמה (passphrase) עדיף.
2. **נעילה והאטה** – אחרי N ניסיונות כושלים: נעילת חשבון, השהיה מתארכת, (exponential backoff), CAPTCHA.
3. **אימות רב-שלבי (MFA)** – גם אם הסיסמה נפרצה, התוקף לא מחזיק את הטלפון.
4. **אחסון סיסמאות נכון** – לא בטקסט גלוי; גיבוב עם salt (פרק 7).
5. **ניטור** – התראה על ריבוי כניסות כושלות (syslog) – פרק 2).

ב-Cisco IOS יש מגנון מובנה שנלמד לעומק בפרק 2, אבל שווה להציג אותו כבר כאן כדי לחבר תיאוריה למעשה:

```
R1(config)# login block-for 120 attempts 3 within 60
! אם היו 3 ניסיונות כושלים תוך 60 שניות - חסום כניסות ל-120 שניות
R1(config)# login delay 2
! השהיה של 2 שניות בין ניסיונות
R1(config)# login on-failure log
! רשום כל כישלון ל-syslog
R1(config)# login on-success log
R1# show login
```

1.8 ארגון האבטחה: מדיניות, תפקידים ותקנים

מדיניות אבטחה (Security Policy)

מסמך שקובע מה מותר ומה אסור בארגון - ולא איך (זה בנהלים). מרכיבים אופייניים: מדיניות שימוש מקובל (AUP), מדיניות סיסמאות, גישה מרחוק, סיווג מידע, תגובה לאירועים. בלי מדיניות כתובה אי אפשר לאכוף ולא ניתן לפטר עובד ש"רק בדק".

סוגי בקורות (נשאל בבגרות - שאלה 6ב)

סוג בקרה	תיאור	דוגמאות
מנהלית (Administrative)	מדיניות, נהלים, הנחיות, תקנים, הדרכות, בדיקות רקע	איסור על עבודה ב-Zoom מרשת לא מאובטחת, נוהל סיסמאות, הכשרת עובדים
פיזית (Physical)	הגנה על החומרה והמבנה	מנעולים על חדר שרתים וארונות תקשורת, מצלמות, שומרים, כרטיסי כניסה
לוגית / טכנית (Logical / Technical)	אמצעים בתוכנה ובחומרה	רשימות גישה (ACL), סיסמאות, הצפנה, חומת אש, IPS, אנטי-וירוס

תפקידים

CISO (Chief Information Security Officer) - אחראי אבטחה ארגוני; SOC (Security Operations Center) - מרכז ניטור 24/7; CERT/CSIRT - צוות תגובה לאירועים; בישראל: מערך הסייבר הלאומי ו-CERT-IL.

תקנים וארגונים

- ISO/IEC 27001 - תקן בינלאומי לניהול אבטחת מידע (ISMS); ארגונים מוסמכים לו.
- NIST Cybersecurity Framework - Identify, Protect, Detect, Respond, Recover.
- PCI-DSS - חובה לכל מי שמעבד כרטיסי אשראי.
- CVE (Common Vulnerabilities and Exposures) - מאגר עולמי של פגיעויות עם מזהה, לדוגמה CVE-2017-0144 (הפגיעות ש-WannaCry ניצלה). CVSS - ציון חומרה 0-10.
- Top 10 SANS, OWASP (Top 10 SANS, OWASP) - לאפליקציות (web, MITRE ATT&CK) - קטלוג טקטיקות תוקפים.

1.9 אביזרי אבטחה ברשת - מפת הקורס

סקירה של הרכיבים שנלמד בפרקים הבאים, כדי שהתלמידים יראו את התמונה הגדולה:

רכיב	תפקיד	פרק
נתב מוקשח (Hardened router)	קו ההגנה הראשון בקצה; SSH, סיסמאות, logging	2
שרת AAA (RADIUS/TACACS+)	אימות מרכזי של משתמשים ומנהלים	3

פרק	תפקיד	רכיב
4	סינון תעבורה לפי כללים	חומת אש / ACL / Firewall) / ZPF
5	זיהוי וחסימת התקפות לפי חתימות	IDS / IPS
6	הגנה בשכבה 2	מתג מאובטח, (port security, DHCP snooping, DAI)
7	סודיות ושלמות	הצפנה, PKI
8	ערוץ מוצפן על גבי רשת ציבורית	VPN (IPsec, SSL)
9	בדיקה שהכול עובד	סורקי פגיעויות, ניהול סיכונים

Cisco ASA (Adaptive Security Appliance) – מכשיר ייעודי שמשלב חומת אש, VPN ו-IPS יורשו הנוכחי: Firepower / FTD. בתכנית מוזכר גם Cisco SDM – ממשיך ניהול גרפי ישן; היום. CLI.

טעויות נפוצות של תלמידים בפרק זה

- מבלבלים וירוס ותולעת – השאלה המכריעה: **האם צריך פעולה של משתמש כדי להתפשט?** וירוס – כן. תולעת – לא.
- חושבים שטרויאני משכפל את עצמו – לא. הוא מחכה שיתקינו אותו.
- "DDoS זה וירוס" – DDoS היא התקפה; botnet (שנבנה בעזרת נוזקה) הוא הכלי.
- "Phishing זה וירוס במייל" – phishing הוא הנדסה חברתית; המייל עצמו לא בהכרח מכיל נוזקה, לפעמים רק קישור לאתר מזויף.
- "Hacker = פושע" – הבהירו את white/black/gray hat.

1.10 תרגילים לתלמידים

תרגיל 1 – סיווג אירועים לפי CIA

לכל אירוע, ציינו איזה עיקרון נפגע (יכול להיות יותר מאחד):
 א. תלמיד מצא דרך לשנות ציון במערכת בית הספר. ב. אתר בית הספר קרס ביום ההרשמה. ג. רשימת הטלפונים של ההורים דלפה לקבוצת וואטסאפ. ד. כופרה הצפינה את שרת הקבצים. ה. מישהו האזין לשיחת Zoom שלא הוזמן אליה.

א. שלמות ב. זמינות ג. סודיות ד. זמינות (ואם הם גם מאיימים לפרסם – סודיות) ה. סודיות

תרגיל 2 – וירוס, תולעת או טרויאני?

א. תוכנה בשם "Free-Minecraft-Coins.exe" שמתקינה keylogger. ב. קובץ Excel עם מאקרו שמדביק את כל קובצי ה-Excel האחרים במחשב כשפותחים אותו. ג. תוכנית שסורקת את הרשת, מוצאת מחשבים עם פורט 445 פתוח ומעתיקה את עצמה אליהם. ד. אפליקציית פנס לאנדרואיד ששולחת את אנשי הקשר לשרת בסין.

א. טרויאני ב. וירוס (מאקרו) ג. תולעת ד. טרויאני (spyware)

תרגיל 3 – חישוב חוזק סיסמה

מחשב תקיפה מנסה 10 מיליארד 10^{10} סיסמאות בשנייה. כמה זמן ייקח במקרה הגרוע לפרוץ: א. 6 ספרות. (PIN) ב. 8 אותיות קטנות. ג. 8 תווים מכל 95 התווים. ד. 12 תווים מכל 95 התווים. (חישוב: מספר האפשרויות $10^{10} \div 10^{10}$)

א. $10^6 / 10^{10} = 0.0001$ שנייה. ב. $2.1 \times 10^{11} \approx 26^8 \Rightarrow 21 \sim$ שניות. ג. $6.6 \times 10^{15} \approx 95^8 \Rightarrow 7.6 \sim$ ימים. ד. $5.4 \times 10^{23} \approx 95^{12} \Rightarrow 1.7 \sim$ מיליון שנים. מסקנה: כל תו נוסף מכפיל את הזמן פי 95.

תרגיל 4 – זהו את שלב התקיפה

לתוקף יש את הרצף הבא. סדרו לפי Reconnaissance / Access / DoS, וצינו לכל שלב מה היה אפשר לעשות כדי לעצור אותו:

1. הריץ Nmap על טווח הכתובות של החברה. 2. מצא שרת FTP ישן וניחש את הסיסמה admin/ad-min. 3. העלה לשרת סקריפט שמציף את הראוטר בבקשות. 4. קרא במודעת דרושים שהחברה משתמשת ב-Windows Server 2012.

4: Reconnaissance (פסיבי), 1 (אקטיבי) – הגנה: מדיניות פרסום, IPS שמזהה סריקות. 2: Access – הגנה: סיסמאות חזקות, כיבוי שירותים מיושנים, 3: DoS. login block. – הגנה: rate limiting, IPS, HIPS. על השרת.

תרגיל 5 – דיון: "אני לא מעניין אף אחד"

תלמיד טוען: "אין לי כלום במחשב, למה שמישהו יתקוף אותי?" תנו 4 סיבות שבגללן גם מחשב "לא מעניין" הוא מטרה.

1. הוא יכול להפוך ל-bot (botnet, DDoS, spam), כריית מטבעות. 2. הסיסמאות שלו כנראה זהות לסיסמאות בחשבונות אחרים. 3. (credential stuffing) הוא קפיצת מדרגה לרשת של ההורים/בית הספר. 4. הזהות שלו (חשבון אינסטגרם, מייל) שווה כסף להונאות. 5. כופרה לא בוררת – היא אוטומטית.

1.11 שאלות בסגנון בגרות – עם פתרונות

שאלה 1

משתמש קיבל "SMS: חבילתך ממתינה. לתשלום מכס של 4.90 ₪ לחץ כאן: post-il.delivery-confirm.xyz". מהו סוג ההתקפה?
1. Ping of Death 2. Smishing 3. Buffer overflow 4. (הנדסה חברתית) תולעת
2. הודעת SMS מתחזה עם דחיפות וסכום קטן שנועד להשיג פרטי כרטיס אשראי. הדומיין אינו של דואר ישראל.

שאלה 2

התאימו: (א) קוד שמצמיד את עצמו לקובץ ומתפשט כשמריצים אותו; (ב) תוכנית שמתפשטת ברשת ללא התערבות משתמש; (ג) תוכנה שנראית כמשחק אך פותחת דלת אחורית. אפשרויות: Worm / Trojan / Virus.
(א) Virus (ב) Worm (ג) Trojan

שאלה 3

תוקף שולח אלפי חבילות SYN לשרת ואינו משיב ל-SYN-ACK. איזו התקפה זו ואיזה עיקרון ב-CIA נפגע?
SYN flood (DoS). נפגעת הזמינות. (Availability) טבלת החיבורים החצי-פתוחים מתמלאת.

שאלה 4

מנהל רשת רוצה שהנתב יחסום ניסיונות התחברות ל-60 שניות לאחר 4 ניסיונות כושלים בתוך 30 שניות. כתבו את הפקודה.
login block-for 60 attempts 4 within 30

שאלה 5

עובד לשעבר שעדיין מחזיק בסיסמה ל-VPN של החברה ומוריד ממנה קבצים – לאיזה סוג תוקף הוא שייך? מה הבקרה (מנהלית) שהייתה מונעת זאת?
Insider. נוהל סיום העסקה (offboarding) שכולל ביטול מידי של כל החשבונות – בקרה מנהלית; ביטול החשבון בפועל – בקרה לוגית.

איזה שלב בתקיפה כולל ping sweep ו-port scan? מה הכלי המקובל?

Reconnaissance (סיור/איסוף מידע). Nmap.

1.12 הצעה למעבדה / פעילות

- Wireshark – Telnet מול SSH: הריצו Telnet לנתב ב-Packet Tracer (או במעבדה) ולכדו את התעבורה; הראו את הסיסמה בטקסט גלוי. חזרו על זה עם SSH. זה מכין את פרק 2.
- **ניתוח 5 הודעות דוא"ל:** תנו לתלמידים 5 צילומי מסך (2 phishing, 3) לגיטימיות) ובקשו לסמן את הסימנים. דוגמאות אמיתיות (מטושטשות) עובדות הכי טוב.
- **חישוב חוזק סיסמה:** חשבו עם התלמידים כמה זמן ייקח לפרוץ סיסמה ב-10¹⁰ ניסיונות/שנייה עבור אורכים שונים. המסקנה – אורך מנצח.

עוד דוגמאות מהעולם האמיתי

(2017) NotPetya – הכופרה שלא הייתה כופרה, נזק של 10 מיליארד דולר

NotPetya נראתה כמו כופרה (דרשה תשלום), אך למעשה הייתה Wiper – מחקה את המידע לצמיתות בלי אפשרות שחזור. היא התפשטה דרך ימיטיגל הנכות ונכדע של תוכנת הנהלת חשבונות אוקראינית פופולרית (M.E.Doc) – מתקפת **שרשרת אספקה**. תוך שעות שיתקה חברות ענק: ענקית הספנות Maersk (שנאלצה להתקין מחדש 4,000 שרתים ו-45,000 מחשבים), חברת התרופות Merck, ו-FedEx. הנזק הכולל נאמד ב-10 מיליארד דולר. **לקח לכיתה:** נזקה יכולה להיכנס דרך תוכנה שאתם סומכים עליה ומתעדכנת אוטומטית – לא רק דרך קליק שלכם. וגם: לא כל מה שנראה ככופרה נועד לכסף; לפעמים המטרה היא הרס טהור (מתקפה מדינתית).

פריצת טוויטר של המפורסמים (2020) – הנדסה חברתית בטלפון

קבוצת בני נוער התקשרה לעובדי טוויטר, התחזתה לצוות ה-IT הפנימי, והשיג יטרפ רוסמל שתוא הענכש לכלי ניהול פנימי (vishing – phishing טלפוני). עם הגישה הזו הם השתלטו על חשבונות של ברק אובמה, אילון מאסק, ביל גייטס, אפל ו-Uber, ופרסמו מהם הונאת ביטקוין ("שלחו ביטקוין ואחזיר כפול"). הם גרפו כ-\$118,000 תוך שעות – **בלי לפרוץ אף מחשב**, רק בכוח השכנוע. לקח: אפילו אחת מחברות הטכנולוגיה הגדולות בעולם נפלה להנדסה חברתית. האדם הוא החוליה החלשה, תמיד.

(2017) Equifax – פגיעות אחת שלא תוקנה, 147 מיליון אנשים

חברת דירוג האשראי Equifax איבדה מידע רגיש (מספרי ביטוח לאומי, תאריכי לידה) של 147 מיליון אמריקאים. הסיבה: פגיעות ידועה בספריית Apache Struts, עם מדוק מיישדוח וימז היהש ווקית ולא הותקן. סורק פגיעויות (פרק 9) היה מוצא אותה בדקות. לקח: ניהול עדכונים אינו אירוע חד-פעמי אלא תהליך מתמשך – בדיוק כפי שראינו ב-WannaCry.

תרגיל 6 – זהו את סוג המתקפה

לכל תרחיש, אילו מהמושגים מהפרק מתאימים? (יכול להיות יותר מאחד)

א. עדכון תוכנה לגיטימי הפיץ נזקה מחקת מידע. ב. עובד התקשר והתחזה לתמיכה כדי לקבל סיסמה. ג. חצי מיליון מכשירי IoT הפכו לצבא שהפיל אתרים.

א. מתקפת שרשרת אספקה + Wiper (מדינתית) – NotPetya. ב. הנדסה חברתית / vishing – פריצת טוויטר. ג. Mirai – botnet + DDoS.

תרגיל 7 – חשיבה

בכל שלושת הסיפורים לעיל, איזו בקרה (מנהלית / פיזית / לוגית) הייתה מקטינה את הנזק? תנו דוגמה אחת לכל סיפור.

NotPetya: בקרה לוגית - פילוח רשת וגיווי מנותק (3-2-1) לשחזור. טוויטר: בקרה מנהלית - נוהל שאוסר מסירת גישה בטלפון + אימות זהות; ולוגית - MFA וכלי ניהול עם הרשאות מוגבלות. Equifax: מנהלית - נוהל עדכונים ובדיקות פגיעות תקופתיות.

בנק שאלות שתלמידים שואלים - ותשובות מוכנות

אוסף שאלות שתלמידים סקרנים נוטים לשאול בפרק זה, עם תשובות מוכנות. מסודר לפי נושא - סרקו לפני השיעור.

מוטיבציה ותפיסות שגויות

ש: "אין לי מה להסתיר / אני לא מעניין אף אחד, אז למה שיתקפו אותי?"
ת: רוב ההתקפות אינן ממוקדות אלא תויאנוטיסו תויטמוטוא. גם מחשב "לא מעניין" שווה לתוקף: אפשר להפוך אותו ל-bot ברשת זומבים (פרק 1.4, לגנוב סיסמאות שחוזרות על עצמן באתרים אחרים - credential stuff-ing), להשתמש בו כקרח קפיצה לרשת של בית הספר/ההורים, או להצפין אותו בכופרה ולדרוש כסף. כופרה לא בוררת מטרות.

ש: "אנטי-וירוס מספיק כדי להיות מוגן?"
ת: לא. אנטי-וירוס קלאסי מזהה לפי **חתימות** - תבניות של נזקות תועודי. נזקה חדשה (zero-day) או כזו ששונתה מעט (polymorphic) לא תזוהה. לכן צריך "הגנה לעומק": עדכוני מערכת, הגנת רשת (חומת אש/IPS), גיבוי, והכי חשוב - משתמש שלא לוחץ על כל דבר.

ש: "מה זה zero-day?"
ת: פגיעות שהיצרן עדיין הילע עדוי אל או שאין לה תיקון - "יום אפס" מאז שהתגלתה. תוקף שמחזיק zero-day יכול לנצל אותה בלי שאף הגנה מבוססת-חתימות תזהה אותה. אלה הפגיעויות היקרות והמסוכנות ביותר.

ש: "האקר = פושע?"
ת: לא בהכרח. White hat - בודק חדירה חוקי, באישור. Black hat - פושע. Gray hat - פורץ ללא אישור אך מדווח. המילה "hacker" במקורה היא מי שמבין מערכות לעומק; התקשורת הצמידה לה משמעות שלילית.

נוזקות

ש: "אז מה בדיוק ההבדל בין וירוס לתולעת? זה מבלבל."
ת: שאלת המפתח: טשפתיש ידכ שמתשמ לש הלועפ כירצ מאה וירוס נדבק לקובץ וזקוק למשתמש שירץ אותו. תולעת מתפשטת דבל דרך הרשת בלי אף פעולת אדם (למשל תולעת מוריס, Slammer טרויאני לא משכפל את עצמו כלל - המשתמש מתקין אותו מרצון כי הוא נראה לגיטימי).

ש: "האם מק / לינוקס / אייפון יכולים להידבק בנוזקה?"
ת: כן, כל מערכת יכולה. Windows הוא היעד הנפוץ ביותר כי הוא הכי נפוץ, אבל יש נזקות ל-macOS, לינוקס, אנדרואיד ו-iOS. אף מערכת אינה "חסונה" - זו תפיסה שגויה מסוכנת.

ש: "כדאי לשלם כופר בכופרה?"
ת: הגישה הרשמית (גם של ה-FBI ומערך הסייבר) היא שלשל אל: אין ערובה שתקבלו מפתח, זה מממן פשע, והופך אתכם ליעד חוזר. הפתרון האמיתי הוא **גיבוי** תקין (פרק 9) שמאפשר לשחזר בלי לשלם.

התקפות והגנה

ש: "אם תוקף מפיל אותנו ב-DDoS, למה שלא פשוט נחסום את הכתובת שלו?"
ת: כי ב-DDoS אין כתובת אחת - ההתקפה מגיעה בו-זמנית מאלפי מכשירים נגועים (botnet) בכל העולם, ולעיתים עם כתובות מקור תופיזמ. חסימה ידנית לא מספיקה; צריך סינון בקנה מידה גדול, שירותי ניקוי בענן, ו-rate limiting.

ש: "אדם אחד יכול לבצע DDoS?"
ת: כן - אם הוא שולט ב-botnet (רשת מחשבים נגועים) או שוכר אחד בדארקנט ("DDoS כשירות"). ההבחנה היא לא מספר האנשים אלא מספר תורוקמ התעבורה: DoS = מקור אחד, DDoS = מקורות רבים.

ש: "איך phishing עוקף אנטי-וירוס?"
ת: כי לרוב אין בו נזקה לסרוק - יש רק קישור לאתר מזויף או בקשה להזין פרטים. זו מניפולציה של סדאה, לא של המחשב. אנטי-וירוס לא "רואה" שאתם מקלידים סיסמה באתר מתחזה.

ש: "אם יש נעילה אחרי 3 ניסיונות, למה צריך בכלל סיסמה חזקה?"
ת: כי לא תמיד התוקף עובר דרך מסך ההתחברות. אם דלף פינונתה דסמ של הסיסמאות (גיבובים), התוקף מריץ

מיליארדי ניחושים אופליין על החומרה שלו – שם אין נעילה. סיסמה ארוכה הופכת את זה לבלתי מעשי.

ש: "האם זה חוקי להריץ Nmap או להתקין Kali Linux?"

ת: הכלים עצמם חוקיים לחלוטין (זה כמו פטיש). מה שאסור הוא שומישה בהם על רשת שאינה שלכם וללא אישור בכתב – זו עבירה על חוק המחשבים התשנ"ה-1995. ברשת מעבדה מבודדת שלכם – מותר ומומלץ ללמוד.

ש: "מה ההבדל המדויק בין איום, פגיעות וסיכון?"

ת: **איום** = הגורם המסוכן (האקר, שריפה) – קיים תמיד, לא בשליטתנו. **פגיעות** = החולשה שהאיום מנצל (סיסמה חלשה, פורט פתוח) – זה מה שבשליטתנו. **סיכון** = ההסתברות שהאיום ינצל את הפגיעות, כפול הנזק. מנהלים סיכון על ידי צמצום פגיעויות.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
אבטחת מידע (Information Security)	הגנה על מידע ומערכות מפני גישה, שינוי, חשיפה או השמדה בלתי מורשים.
אבטחת רשת (Network Security)	תת-תחום: הגנה על תשתית הרשת ועל התעבורה שעוברת בה.
סודיות (Confidentiality)	הבטחה שרק גורמים מורשים רואים את המידע. מושגת בהצפנה ובבקרת גישה.
שלמות (Integrity)	הבטחה שהמידע לא שונה ללא הרשאה. מושגת בגיבוב וחתימה דיגיטלית.
זמינות (Availability)	הבטחה שהמידע והשירות נגישים כשצריך. נפגעת ב-DoS ובכופרה.
אימות (Authentication)	הוכחת זהות – מי אתה (שם משתמש וסיסמה, ביומטריה).
אי-הכחשה (Non-repudiation)	מניעת אפשרות של השולח להכחיש ששלח; מושגת בחתימה דיגיטלית.
נכס (Asset)	כל דבר בעל ערך שמגנים עליו: מידע, שרת, מוניטין, זמינות.
פגיעות (Vulnerability)	חולשה שניתן לנצל: באג, סיסמה חלשה, פורט פתוח, עובד לא מודרך.
איום (Threat)	גורם שעלול לנצל פגיעות: האקר, נוזקה, עובד ממורמר, אסון טבע.
סיכון (Risk)	הסתברות שאיום ינצל פגיעות, כפול הנזק. $\text{סיכון} = \text{איום} \times \text{פגיעות}$ ערך הנכס.
בקרה (Control)	אמצעי שמקטין סיכון. מנהלית (נהלים), פיזית (מנעולים), לוגית (הצפנה, ACL).
נוזקה (Malware)	שם כולל לתוכנה זדונית: וירוס, תולעת, טרויאני, כופרה ועוד.
וירוס (Virus)	קוד זדוני שנצמד לקובץ ומתפשט כששתמש מריץ אותו.
תולעת (Worm)	תוכנה שמשכפלת ומתפשטת לבד ברשת, ללא פעולת משתמש.
סוס טרויאני (Trojan)	תוכנה שנראית לגיטימית אך מכילה קוד זדוני; אינה משכפלת את עצמה.
כופרה (Ransomware)	נוזקה שמצפינה קבצים ודורשת תשלום; פוגעת בזמינות.
Rootkit	נוזקה שמסתתרת עמוק במערכת ההפעלה ומסווה נזקות אחרות.
Botnet	רשת מחשבים נגועים (זומבים) הנשלטים מרחוק לביצוע התקפות.

מונח	הגדרה
Backdoor	דלת אחורית שעוקפת את מנגנון האימות ומאפשרת גישה סמויה.
הנדסה חברתית (Social Engineering)	מניפולציה של בני אדם כדי להשיג מידע או גישה (במקום פריצה טכנית).
Phishing	דוא"ל/הודעה מתחזים המבקשים ללחוץ על קישור או למסור פרטים.
DoS / DDoS	מניעת שירות - הצפת שירות עד קריסה, ממקור אחד (DoS) או ממקורות רבים (DDoS)
SYN flood	הצפת שרת בבקשות SYN חצי-פתוחות עד שטבלת החיבורים מתמלאת.
Buffer overflow	שליחת קלט ארוך מהחוצץ, שגולש ודורס זיכרון ומריץ קוד תוקף.
Brute force	ניסוי שיטתי של כל הסיסמאות האפשריות (או רשימת מילון) עד למציאה.
Reconnaissance	שלב הסיור - איסוף מידע על המטרה (whois, sniffing), סריקת פורטים, .
Zero-day	פגיעות שאין לה עדיין תיקון או שאינה ידועה ליצרן.